

A little pause. A lot of protection.

ScamGuard recognizes the financial scam workflow, then intervenes at a risky action.

A scam is a journey, not just a suspicious caller.

Messages, calls, links, QR codes and payment requests become one user-controlled local session. Behavior matters even when voices and scripts are generated by AI.

USER-CONTROLLED

Check only when you choose. Local inference.
No ordinary call recording. No banking
credentials. No automatic blacklist.

Working web reference prototype + a practical Android/PSP deployment path.
This document contains 10 pitch slides, 3 architecture pages and 2 disclosure/reference appendices.

The vulnerable moment is before money moves.

Primary user: a UPI user facing unfamiliar financial instructions, especially under time pressure.

User need

A clear reason to pause, in plain language, without uploading an entire conversation.

Threat scenario

A plausible official voice, templated chat or investment promise moves the user from trust to secrecy, app installation, credentials and a transfer.

Why single-channel checks miss context

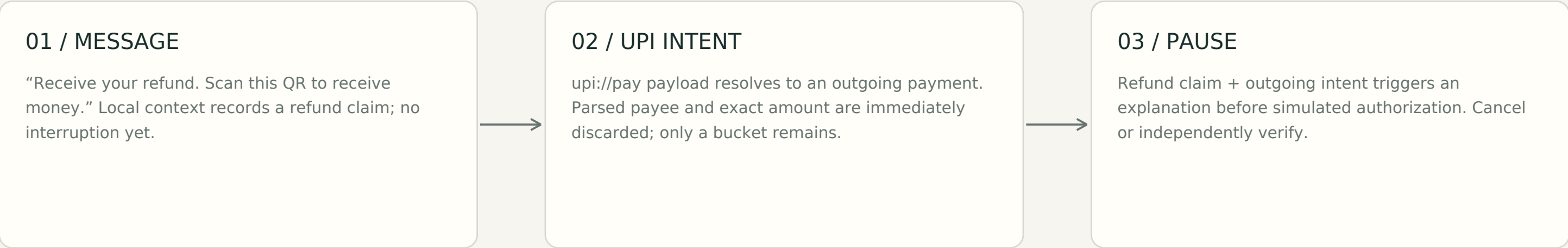
A refund message can sound harmless; an outgoing QR is a normal payment primitive. Together they contradict the promise of receiving money.

Scope and limits

Targets scam behavior irrespective of AI origin. It does not prove a voice is cloned, inspect arbitrary bank apps, or intercept ordinary cellular-call audio.

A refund message becomes an outgoing payment.

Synthetic demonstration: the warning is attached to the harmful transition.



Ordinary counterexample: a restaurant QR and known merchant context proceed without a warning. Every decision uses the same engine.

No money moves. Calls are typed/consented transcripts. QR screenshots and optional camera frames decode locally using native detection or bundled jsQR. Text sharing uses a private PWA POST target.

Small local models. Explicit workflow logic.

The phone-facing path stays light; server connectivity is not required for a local warning.

Tier 0: cheap extraction

NFKC/invisible-control normalization, thirteen tactic rules, negated-advice handling and strict UPI intent parsing.

Tier 1: compact AI support

Eleven binary word/bigram logistic heads. 157 disclosed synthetic training texts. Exported JSON model: 148 KiB. No hosted LLM.

Temporal session

User chooses one active conversation; at most 64 derived events; 20-minute inactivity expiry. Ordered pretext-to-action patterns plus coarse payment escalation.

Guarded decisions

An action-aware gate needs a matched workflow and independent signals, or a direct request for a secret. ML corroboration contributes at most 3 points and cannot warn alone.

Warning less is part of protecting better.

Suspicion and action risk are separate heuristic indices, not calibrated probabilities.

Passive before an action

Suspicious wording alone adds context. Evidence remains visible without interrupting the user.

Useful at the transition

Explain what happened: a refund led to an outgoing QR, authority and threat led to transfer, or a request sought secret credentials.

Limit repetition

60-second suppression. Re-warn for a different matched workflow, increased severity, a new sensitive action, or a financial increase of at least two amount buckets.

Human agency

Cancel the simulated request or confirm continuation after a second review. The product never promises safety from a low score. Feedback is not automatic retraining.

New patterns become candidates for review.

Emerging workflows are an intelligence problem, not a licence to blacklist people.

Minimum data

User separately consents to sharing tactic/channel enums, sequence, amount bucket, count and a random session ID. No transcript, VPA, audio or exact amount.

Implemented discovery baseline

Jaccard ≥ 0.70 plus ordered LCS ≥ 0.70 . Three session reports create a candidate. Two fixed 20-report windows provide a Hoeffding distribution-shift cue.

Human review

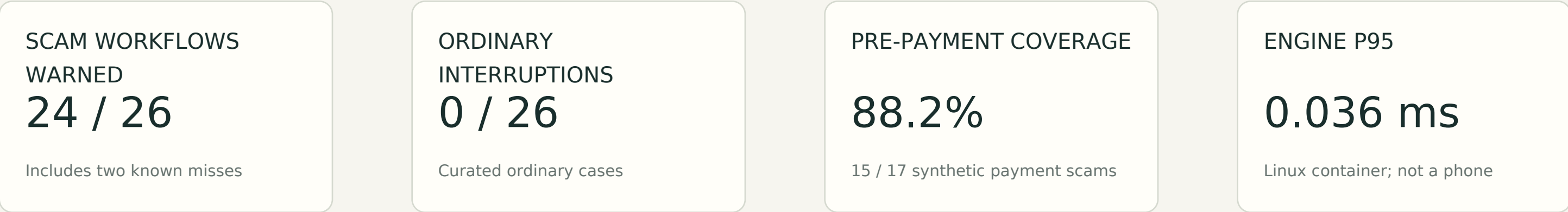
Token-gated analyst marks a candidate reviewed or dismissed. No candidate changes the local warning policy or labels a payment account as fraudulent.

Research extension

A synthetic shift (20 ordinary then 20 new-composition reports) is detected. The bound assumes independent reports; identities are unverified. Compare HDBSCAN/ADWIN after reporter trust is established.

Validation that names its limits.

20 smoke + 32 later AI-authored challenge workflows. No real-world accuracy or real-phone performance claim.



Current checks

29 automated tests: negation, Unicode evasion, ordered timing, stale-session reset, UPI ambiguity, warning upgrade, PII exclusion, consent, deletion, retention and analyst gate.

Open evidence gaps

Two known misses: indirect coercion and implicit yield. Rules and hybrid warn on the same 24 cases, so no ML recall improvement is claimed. Test licensed traffic, family/time splits and actual phone latency/battery.

Privacy is an implementation constraint.

Data minimization does not mean “risk free”: fingerprints and consent remain sensitive.

Default off

Camera only after user activation, for QR scanning. No microphone, notifications, SMS, call-log or banking access. Pattern sharing and usage analytics are separate visit-only opt-ins. All local checks work without analytics.

Bounded retention

Derived local session stays in memory; raw input clears after analysis. Shared fingerprints expire after 24 hours; an opaque session ID enables deletion.

Security controls

Localhost binding, bounded JSON, enum allowlists, request limits, same-origin validation, CSP, static route containment and no content access logs.

Known limits

Prototype reports are not identity-verified. Browser memory and SQLite pages do not guarantee forensic erasure. Public deployment needs TLS, authenticated reporters, quotas, audit controls and security review.

Start with sharing. Integrate before authorization.

Adoption pathway: give the user control now; deepen protection only with authorised access.

Today: usable reference MVP

Phone-first PWA; private POST share target; local QR images/camera; ML/rules; 52-scenario lab; ordered campaign inbox; redacted exports; opt-in PostHog.

Next: native Android

Sharesheet and QR adapters. User-triggered controlled VoIP with consented LiveKit/sherpa audio. Typed transcripts remain a reliable demo fallback.

Partner pathway

Bank/PSP/wallet sandbox sends PaymentEvent before authorization. Same lightweight engine returns contextual warning and user review; it does not scrape other apps.

Scale deliberately

Move local SQLite reference service to authenticated ingestion and durable encrypted storage. Add validated drift/clustering and reviewed signed policy snapshots. Keep graph models off the phone hot path.

A credible 48-hour build, with a baseline already working.

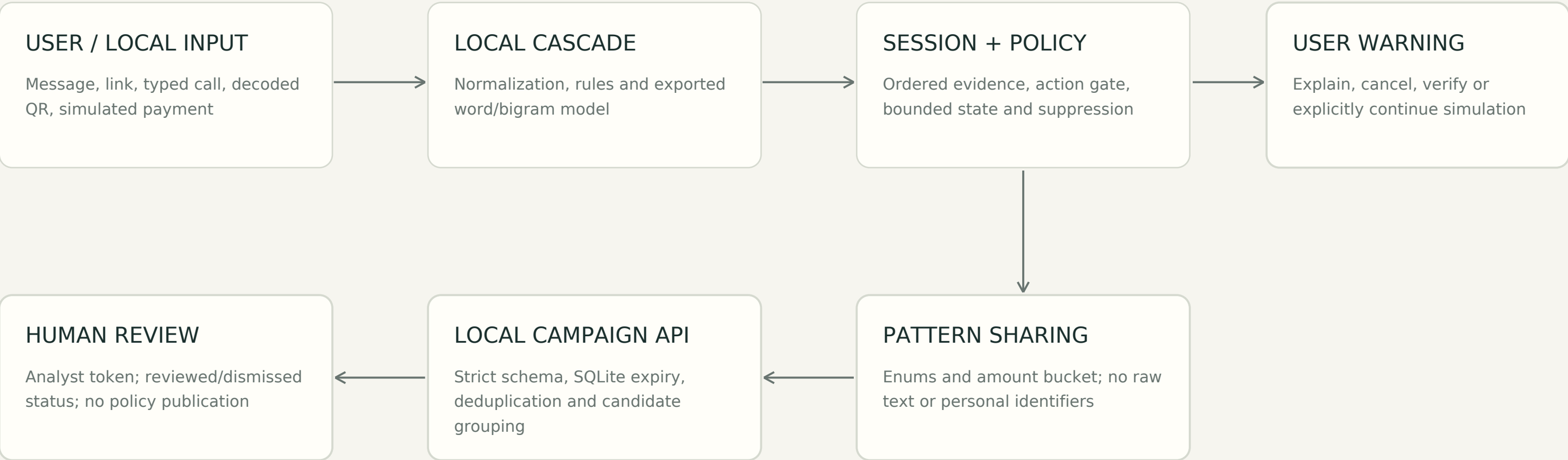
2-4 students; combine app/UX and engine/validation roles for a two-person team.

00-12 HOURS	Reproduce baseline; lock data contracts and test suite; build Android share/QR adapter if tooling is ready.
12-24 HOURS	Complete payment simulator + local warning trace; optional consented VoIP/ASR with typed fallback; verify deletion and logs.
24-38 HOURS	Rules/hybrid ablation; independent paraphrases; poisoning tests; real-device timing; accessibility and consented usability.
38-48 HOURS	Freeze versions; disclose AI/data/assets; rehearse refund + investment + benign QR; prepare a backup runnable build.

Success targets to test, not claim: <300 ms P95 payment warning on a midrange device; <2 interruptions per 100 independently labelled legitimate flows; >90% representative pre-payment intervention.

End-to-end system and trust boundaries.

Solid arrows are implemented. Future audio/Android/PSP adapters enter the same event contract.



Separate optional analytics path: explicit user opt-in -> coarse allowlisted events -> configured PostHog transport. Failure never delays protection. Production requires authenticated reporters and a signed threat-update boundary.

Detection, data flow and intervention policy.

A deterministic rule-led cascade with bounded ML corroboration makes the decision reviewable.

Input and feature contract

One event: channel, text or simulated payment, monotonic timestamp. Parse locally. Retain only tactic enums, model scores, derived coarse payment information and timing.

Workflow matching

Refund -> outgoing QR; authority + pressure -> transfer; guarantee -> escalating investment payment; fee-to-unlock; remote-control support; direct credential request. Ordered pretext checks prevent arbitrary keyword pooling.

Gate and output

No risky action: quiet/watch. Matched action + sufficient independent signals: warning/high. Repeat suppress for 60s unless risk increases. Return reason, stage, evidence index, action-risk index and a user choice.

Fingerprint schema

version; random session_id; tactic set; ordered tactic sequence; channel set; amount_bucket; event_count. Maximum 64 events. Unknown fields, raw content and non-enum strings are rejected.

Review, escalation and operational safeguards.

No automatic blocking, threat-policy publication or fraud-account identification in the prototype.

Candidate -> review

Distinct random session reports cluster by tactic and ordered-sequence similarity. Fixed 20/20 windows expose a shift cue under independence assumptions. Three reports create an unverified candidate. Analyst auth is required to mark reviewed or dismissed. A reviewed candidate is not proof of fraud.

User escalation path

Pause; contact the institution through independently sourced official details; export the redacted report. In a real suspected financial fraud, use official reporting channels. Automated external reporting is not implemented.

Abuse and security

Sybil/poisoning threat is explicit. Rate limiting and deduplication are only baseline controls. Public rollout must add reporter trust, device/session attestation where appropriate, encrypted storage, auditability and red-team validation.

Privacy lifecycle

Raw input never enters API, analytics or cache. Fixed public app assets alone are cached offline. User-controlled report deletion; 24-hour server expiry. Granular consent; no SDK autocapture, replay or person profiles.

AI and asset disclosure.

All synthetic assets and models are labelled; no confidential customer or bank data is used.

AI-generated content

ChatGPT/Codex generated code, documentation, visual design, SVG shield, synthetic text/scenarios and this PDF under user direction. Human review is required before contest submission.

Datasets and model

157 AI-authored training texts; 52 workflows (26 scam, 26 ordinary), including 32 later challenge fixtures. Two indirect scams are known misses. Eleven scikit-learn logistic heads; no ASR, deepfake or graph model ships.

Third-party runtime and tools

Python/SQLite; browser APIs; bundled jsQR 1.4.0 (Apache-2.0); Node tests. scikit-learn 1.8.0 for training (BSD-3-Clause); ReportLab for PDF (BSD); Playwright for development checks; official GitHub actions. Optional PostHog capture API.

Visual and research assets

System font stacks in app; DejaVu fonts embedded in PDF; original generated SVG. No bank/company logos or stock imagery. Earlier pasted research statistics are not reproduced as independently verified results. All data/model artefacts are in the repository.

References and reproducibility.

This PDF stands alone. Links below are operational references, not required to understand the proposal.

Android: developer.android.com/reference/android/telecom/CallScreeningService

NPCI: npci.org.in/safety-feature

scikit-learn: scikit-learn.org/stable/modules/generated/sklearn.linear_model.LogisticRegression.html

PostHog: posthog.com/docs/api/capture and [/docs/product-analytics/capture-events](https://posthog.com/docs/product-analytics/capture-events)

Mobile QR/share: bundled jsQR 1.4.0 (Apache-2.0); MDN Web App Manifest `share_target`.

Reproduce: `python3 backend/server.py`; `npm test`; `npm run evaluate`; `npm run qa`.

Source: github.com/1shu1iwari-crypto/AI-Protect (feat/scamguard-mobile-workflows).

Before upload: add actual team names/eligibility details and independently verify organiser requirements. No contest registration or submission has been performed.